Семинар 10

Управление рисками IT-проекта

Идентификация, анализ, реагирование и предотвращение провалов проекта

Источники и материалы

- PMBOK: область знаний «Управление рисками проекта» — 6-шаговый процесс от планирования до мониторинга
- Ика и Сен-Макари, «Managing Fuzzy Projects in 3D» — политическое и психосоциальное измерения провала
- Standish Group, CHAOS Report — многолетние данные о причинах провалов IT-проектов
- Количественный анализ рисков: ожидаемая денежная стоимость (EMV), сравнение сценариев реагирования

Почему управление рисками — не бумажная формальность

- По данным многолетних исследований Standish Group (CHAOS Report), лишь меньшая часть IT-проектов укладывается в срок, бюджет и полный объём заявленных функций — и системное управление рисками статистически связано с более высокой долей успешных проектов
- Большинство провалов не вызваны «непредсказуемыми чёрными лебедями» — они вызваны рисками, которые были идентифицируемы заранее, но не были формализованы, оценены или получили неверную стратегию реагирования
- Сегодняшнее занятие устроено иначе, чем предыдущие: почти все инструменты дают не единственно верный алгоритм, а способ структурировать выбор между несколькими правдоподобными вариантами — и часто интуитивно «безопасный» вариант оказывается хуже при точном расчёте
- **Все командные задания сегодня сконструированы так, что очевидный на первый взгляд ответ — не обязательно правильный: это не ошибка формулировки, а суть работы с риском в реальных проектах**

A

Основы и инструменты риск-менеджмента

Процесс, идентификация, анализ, реагирование, мониторинг

Процесс управления рисками (PMBOK)



Мониторинг рисков — это непрерывный цикл, а не разовый этап: новые риски появляются и переоцениваются на протяжении всего проекта

- Планирование управления рисками задаёт «правила игры»: шкалы вероятности/влияния, пороги эскалации, роли
- Мониторинг замыкает цикл: по факту работы риски переоцениваются, появляются новые, часть закрывается

Методы идентификации рисков

- Мозговой штурм и экспертные интервью — свободный сбор идей от команды и заинтересованных лиц, без критики на этапе генерации
- Контрольные списки (checklists) — риски, типичные для данного класса проектов (например, риски интеграции с внешним API — почти всегда в IT-проектах)
- Анализ допущений и ограничений — что мы считаем истинным без доказательств? Что произойдёт, если допущение окажется неверным?
- SWOT-анализ — угрозы и слабые стороны напрямую превращаются в кандидатов на риски
- Метод Дельфи — анонимный опрос экспертов в несколько раундов, снижает влияние группового давления и авторитета на оценку
- Анализ причинно-следственных связей (диаграмма Исикавы) — помогает найти корневые причины, а не только симптомы

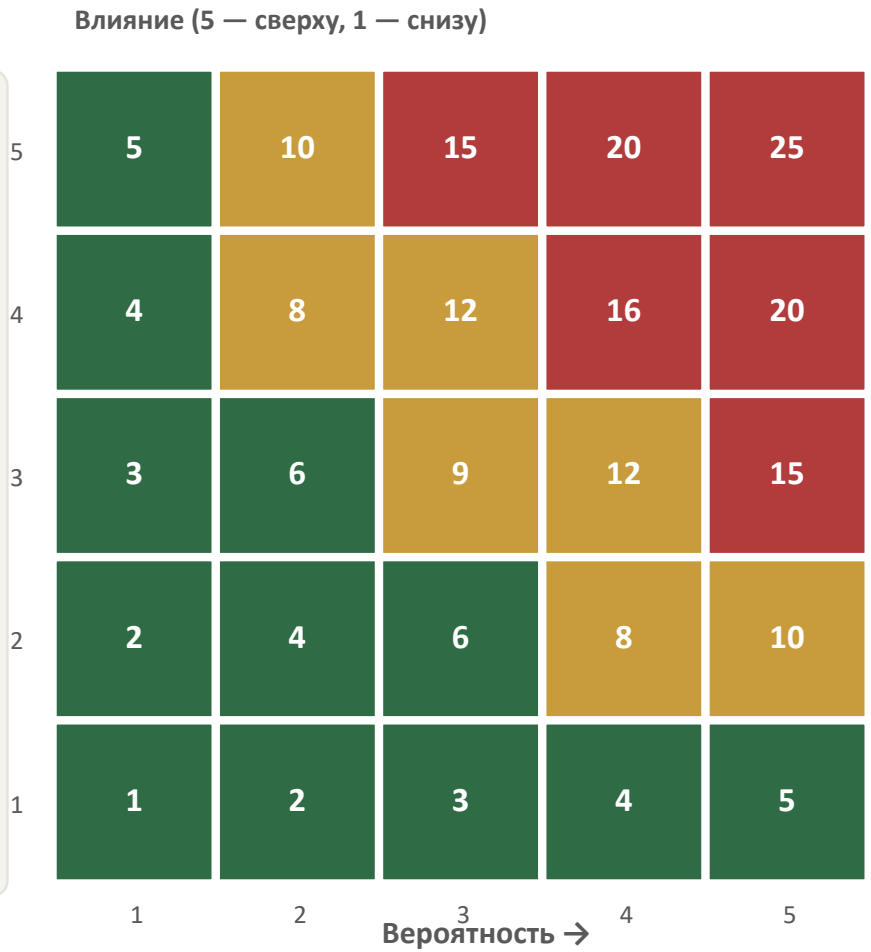
Реестр рисков: обязательные поля

Поле	Назначение
ID и описание риска	Формулировка «причина → событие → последствие», а не общие слова вроде «риски интеграции»
Категория	Технический / организационный / внешний / управление проектом — облегчает поиск паттернов
Вероятность (1–5)	Экспертная или статистическая оценка вероятности наступления
Влияние (1–5)	Оценка воздействия на срок, бюджет, качество или репутацию
Оценка риска	Вероятность × Влияние — определяет приоритет и зону в матрице
Стратегия реагирования	Избежать / передать / снизить / принять (для угроз)
Владелец риска	Конкретный человек, отвечающий за мониторинг и триггеры — не «команда» в целом
Триггеры	Ранние признаки того, что риск начинает реализовываться
Статус	Открыт / реализуется / закрыт / устарел

Матрица «Вероятность × Влияние»

Зоны

- Низкий (1–6): мониторинг без активных действий
- Средний (8–12): планировать меры реагирования
- Высокий (15–25): требует немедленного плана реагирования и владельца риска



Ограничение метода

Качественная оценка субъективна: разные эксперты по-разному оценивают одну и ту же вероятность. Для критичных решений её дополняют количественным анализом — а иногда числа переворачивают интуитивный приоритет.

Ожидаемая денежная стоимость (EMV)

– EMV = Вероятность × Денежное влияние — переводит риск в сопоставимую денежную величину и позволяет сравнивать варианты реагирования, а не полагаться на интуицию

Пример: риск срыва поставки цветов от основного оптовика в пиковый день

Сценарий	Доп. затраты	Вероятность дефицита	Потери при дефиците	EMV
Ничего не делать	0 ₽	35%	–900 000 ₽	**–315 000 ₽**
Буферный запас у того же поставщика	–70 000 ₽	12%	–900 000 ₽	**–178 000 ₽**
Контракт с резервным поставщиком	–120 000 ₽	2%	–900 000 ₽	**–138 000 ₽**

– Интуитивный выбор — «заказать больше цветов про запас» — кажется дешёвым и разумным решением

– **Расчёт показывает обратное: формальный контракт с резервным поставщиком (EMV –138 000 ₽) выгоднее буферного запаса (EMV –178 000 ₽) — обязывающее соглашение снижает вероятность гораздо сильнее, чем неформальный излишек товара**

Стратегии реагирования на угрозы

Избежать

Изменить план так, чтобы устранить причину риска целиком

Пример:

Отказаться от непроверенной технологии в пользу проверенной

Передать

Переложить последствия на третью сторону

Пример:

Страхование, фиксированная цена в контракте с подрядчиком, SLA с провайдером

Снизить

Уменьшить вероятность и/или влияние риска

Пример:

Дополнительное тестирование, резервный поставщик, буфер в графике

Принять

Осознанно ничего не делать заранее, но заложить резерв

Пример:

Активное принятие — план Б наготове; пассивное — просто резерв бюджета

Различие между активным и пассивным принятием вернётся в задании 5 — оно нетривиально и часто определяет правильность решения

Риски бывают и позитивными: стратегии для возможностей

– В PMBOK риск — не только угроза, но и возможность (positive risk). Управлять нужно и тем, и другим

Стратегия	Смысл	Пример из IT-проекта
Использовать (Exploit)	Сделать всё, чтобы возможность точно реализовалась	Досрочно готовая функция — выделить ресурсы, чтобы гарантированно успеть к акции
Разделить (Share)	Привлечь партнёра, который лучше использует возможность	Отдать модуль аналитики специализированному подрядчику с готовой экспертизой
Усилить (Enhance)	Повысить вероятность или эффект возможности	Дополнительное тестирование A/B, чтобы раньше подтвердить рост конверсии
Принять (Accept)	Не предпринимать активных действий, воспользоваться, если сложится	Не менять план, но зафиксировать, что делать, если бонус-фича успеет вовремя

Резервы: снова о контингентном и управленческом

- Напоминание из занятия 6: контингентный резерв (Contingency Reserve) закладывается на известные риски и входит в базовый бюджет (Cost Baseline) — им управляет руководитель проекта
- Управленческий резерв (Management Reserve) — на неизвестные риски («неизвестные неизвестные»), НЕ входит в базовый бюджет, им распоряжается спонсор
- Связь с сегодняшней темой: величина контингентного резерва должна логически следовать из реестра рисков (сумма EMV значимых рисков), а не браться «на глазок» как процент от бюджета
- **Если риск реализовался и резерв исчерпан — это сигнал для пересчёта EAC и обсуждения с спонсором об управленческом резерве, а не для тихого урезания качества**

Почему проваливаются IT-проекты

- По многолетним наблюдениям Standish Group (CHAOS Report), только меньшинство IT-проектов завершаются точно в срок, в бюджет и с полным согласованным набором функций
- Наиболее часто повторяющиеся причины провалов: нечёткие или постоянно меняющиеся требования; недостаточная вовлечённость заказчика; нереалистичные сроки и оценки; слабая коммуникация между техническими и бизнес-стейкхолдерами; отсутствие поддержки со стороны руководства
- **Важно: это преимущественно организационные причины, а не отсутствие технических методологий управления рисками — реестр и матрица сами по себе не спасают проект без политической воли ими пользоваться**

Скрытые причины: политическое и психосоциальное измерения

- Оптимизм-искажение (Kahneman/Lovallo) — команда искренне недооценивает риски и переоценивает свои возможности, без злого умысла
- Стратегическое искажение (strategic misrepresentation) — оценки сроков и бюджета сознательно занижаются, чтобы проект был утверждён («иначе не одобрят»)
- Принцип «скрытой руки» (Hidden Hand, Хиршман) — иногда заниженная оценка сложности неожиданно компенсируется тем, что трудности стимулируют изобретательность команды; эмпирически спорен (Фливбьорг оспаривает частоту такого исхода)
- Практический вывод для риск-менеджмента: часть рисков в реестре нужно формулировать не как «сервер может упасть», а как «оценка бюджета могла быть сознательно занижена ради утверждения проекта» — и такой риск требует политических, а не только технических мер реагирования

Красные флаги: сигналы будущего провала

- Статус-отчёты неделя за неделей одинаковы («всё по плану») без конкретных цифр прогресса
- Критические вопросы решаются в кулуарах, а не выносятся на общие обсуждения
- Растёт число задач в статусе «в процессе», но не растёт число задач «сделано»
- Ключевые стейкхолдеры перестают приходить на демо и ревью
- Оценки задач систематически превышаются, но метод оценки не пересматривается
- Появляется феномен «90% готово» — задача месяцами близка к завершению, но не завершается

Частые ошибки в управлении рисками

Ошибка	Почему это проблема	Как избежать
Реестр рисков составлен один раз на старте	Новые риски и изменение вероятности/влияния остаются незамеченными	Пересматривать реестр на регулярных контрольных точках, а не только на старте
Выбор «самой безопасной» стратегии без расчёта	Интуитивно надёжный вариант может быть дороже в ожидаемом выражении из-за скрытых вторичных рисков	Считать EMV и явно учитывать риски, которые создаёт сама стратегия реагирования
У риска нет владельца	Никто не отслеживает триггеры — риск реализуется незаметно	Назначать персонального владельца на каждый значимый риск
Путают активное и пассивное принятие	Пассивное принятие без плана Б оставляет команду без действий в момент кризиса	Для принятых рисков явно фиксировать: есть ли готовый план Б и триггер для его запуска

Реестр рисков проекта «ФлораЭкспресс» (фрагмент)

Риск	Вер.	Вл.	Оценка	Стратегия	Владелец
Провайдер SMS-уведомлений задержит подключение API	4	3	12	Снизить: параллельно тестировать резервного провайдера	Backend-лид
Пиковая нагрузка в праздники обрушит сервис	3	5	15	Снизить: нагрузочное тестирование заранее, автоскейлинг	DevOps-инженер
Основной оптовик не поставит цветы в пиковый день	2	4	8	Снизить: контракт с резервным поставщиком (см. расчёт EMV)	Менеджер по продукту
Флорист-партнёр задержит обновление каталога	2	2	4	Принять: мониторинг без активных мер	Менеджер по продукту

Обратите внимание: строка про оптовика — тот же риск, что разобран количественно на слайде про EMV. Качественная оценка (8, «средний») не показывает, что среди стратегий «снизить» разные варианты дают разный результат — для этого нужен количественный анализ.

В

Задания для команд

ЗАДАНИЕ

Как устроено задание

- 1. У каждой команды — риск с 2–3 вариантами реагирования и конкретными числами (вероятности, суммы, сроки). Один из вариантов выглядит «очевидно безопасным» — задача команды проверить это расчётом, а не интуицией
- 2. Посчитайте EMV для каждого предложенного варианта, где это применимо, и явно покажите расчёт — не только итоговое число
- 3. Проверьте, не создаёт ли «безопасный» вариант новый, вторичный риск (по срокам, по отношениям со стейкхолдером, по репутации), который не виден в исходных числах
- 4. Если ни один из предложенных вариантов не является хорошим решением — предложите свой, но обоснуйте его так же строго, как если бы он был в списке изначально
- 5. Явно ответьте на вопрос: есть ли в вашем случае аргумент, который заставил бы отклониться от варианта с лучшим EMV (репутационный, регуляторный, политический)? Если да — сформулируйте его как отдельный тезис, а не заметку в скобках

Платёжный шлюз перед распродажей

Проект: интернет-магазин электроники

Ситуация

До крупной сезонной распродажи — 3 недели. Текущий платёжный шлюз даёт сбои под высокой нагрузкой: вероятность критического отказа именно в дни распродажи оценена в 30%, потери при отказе — 1 800 000 ₽ (упущенные продажи и возвраты).

Предложенные варианты

– Вариант А — срочно перейти на более надёжного провайдера. Стоимость перехода — 350 000 ₽. Интеграция обычно занимает 3–4 недели у команды такого размера, то есть есть риск не успеть к самой распродаже (оцените этот риск сами, исходя из того, что «обычно» — не то же самое, что «в срок»).

– Вариант Б — остаться на текущем провайдере, но вложиться в нагрузочное тестирование и автоматический переключатель на резервный канал оплаты — 180 000 ₽, снижает вероятность отказа до 8%.

Подсказка

Посчитайте EMV для обоих вариантов — но для варианта А явно учтите ДВА возможных исхода (успели перейти в срок / не успели), а не только стоимость перехода. Что произойдёт с продажами, если к дате распродажи новый провайдер не подключён, а старый уже отключать поздно или уже отключили?

Структура ответа: расчёт EMV по вариантам (где применимо) → проверка вторичных рисков → явный выбор с обоснованием → политический/репутационный аргумент, если он есть

Аудит перед запуском мобильного банкинга

Проект: мобильный банкинг-сервис

Ситуация

Перед релизом модуля переводов юридический отдел требует проверку на критические уязвимости. Есть основания полагать, что вероятность существования такой уязвимости в коде — 20%, независимо от того, кто и как её ищет (это свойство самого кода, а не аудита).

Предложенные варианты

– Вариант А — внутренний аудит силами штатной команды безопасности: 400 000 ₽, находит существующую уязвимость с вероятностью 60%.

– Вариант Б — сертифицированный внешний пентест: 2 200 000 ₽, находит уязвимость с вероятностью 92%, но задерживает релиз на 3 недели.

Подсказка

Если уязвимость останется незамеченной и её найдут после запуска регулятор или злоумышленник, ущерб (штраф, ремонт репутации, принудительный откат функции) оценивается в 12 000 000 ₽. Посчитайте ожидаемые полные затраты для обоих вариантов. Когда посчитаете — задайте себе отдельный вопрос: одинаково ли банк должен относиться к ожидаемому значению и к риску катастрофического хвоста, если речь о регуляторе?

Структура ответа: расчёт EMV по вариантам (где применимо) → проверка вторичных рисков → явный выбор с обоснованием → политический/репутационный аргумент, если он есть

Пилот электронной медкарты: сорвать пилот или сорвать данные

Проект: электронная медицинская карта (ЭМК)

Ситуация

Пилот идёт в одном отделении, у больницы жёсткий контрактный срок оценки результатов — 2 месяца, с штрафом за перенос. Через месяц ясно: часть врачей ведёт записи на бумаге параллельно с системой, из-за чего данные для итоговой оценки эффективности неполны.

Предложенные варианты

- Вариант А — жёстко обязать всех врачей отделения полностью перейти на систему с этой недели под контролем заведующего отделением.
- Вариант Б — продлить период параллельного ведения записей ещё на месяц с усиленным обучением, попросив больницу перенести срок итоговой оценки.

Подсказка

Подумайте не только о вероятности успеха каждого варианта, но и о том, что именно измеряет итоговая оценка пилота: если врачи перейдут на систему «под принуждением» за неделю до отчёта, что это скажет о реальном качестве данных в отчёте — и о том, повторится ли сопротивление после окончания пилота, когда контроля заведующего уже не будет?

Структура ответа: расчёт EMV по вариантам (где применимо) → проверка вторичных рисков → явный выбор с обоснованием → политический/репутационный аргумент, если он есть

Ненадёжный провайдер трек-API

Проект: логистическая платформа отслеживания грузов

Ситуация

Провайдер API для интеграции с транспортными компаниями уже третий раз подряд срывает сроки поставки тестовой среды. До обязательного релиза MVP — 5 недель, дата зафиксирована в контракте с первым корпоративным клиентом.

Предложенные варианты

- Вариант А (теоретически «правильный», но обсудите его осуществимость) — разработать собственный модуль трекинга внутри компании, полностью исключив зависимость от провайдера.
- Вариант Б — сменить провайдера на другого, менее известного, с формально более быстрым откликом, но без проверенной истории надёжности.
- Вариант В — остаться с текущим провайдером, но добавить постоянный мониторинг с ручным резервным процессом на случай очередного срыва.

Подсказка

Один из трёх вариантов лучше всех остальных «по учебнику» (полностью устраняет риск), но его нельзя реализовать за 5 недель. Задание — не выбрать теоретически идеальную стратегию, а найти лучшую ДОСТИЖИМУЮ в заданный срок, и явно объяснить, почему вы отклонили более «правильный» вариант.

Структура ответа: расчёт EMV по вариантам (где применимо) → проверка вторичных рисков → явный выбор с обоснованием → политический/репутационный аргумент, если он есть

LMS-платформа: риск, который нельзя устранить вовремя

Проект: университетская LMS-платформа

Ситуация

До начала учебного года — 8 недель, дата абсолютно неподвижна (расписание вуза невозможно перенести). Интеграция с системой прокторинга у выбранного вендора нестабильна и может не заработать к сроку с вероятностью 25%.

Предложенные варианты

– Вариант А — сменить вендора прокторинга на более стабильного. Требует 6 недель на новую интеграцию и тестирование — почти весь оставшийся запас времени.

– Вариант Б — принять риск: университет запускает LMS без гарантии прокторинга к 1 сентября, полагаясь на резервный ручной формат контроля экзаменов.

Подсказка

Оба варианта на первый взгляд выглядят как отказ от полноценного решения проблемы. Разберитесь, чем ПАССИВНОЕ принятие риска отличается от АКТИВНОГО — и что именно должно быть заранее подготовлено во втором варианте, чтобы он не превратился в панику 1 сентября.

Структура ответа: расчёт EMV по вариантам (где применимо) → проверка вторичных рисков → явный выбор с обоснованием → политический/репутационный аргумент, если он есть

Сертификация регулятором

Проект: портал государственных услуг

Ситуация

Портал госуслуг не может быть запущен публично без сертификации по информационной безопасности. Исторически сроки такой сертификации у регулятора непредсказуемы и могут занять от 3 до 10 недель. Ведомство-заказчик рассчитывает на запуск «к концу квартала» и публично анонсировало эту дату.

Предложенные варианты

– Вариант А — дождаться полной сертификации, не анонсируя ничего до её завершения, даже если это означает пропуск объявленной даты.

– Вариант Б — запустить ограниченную публичную версию (пилотный набор услуг) параллельно с прохождением сертификации на полную версию.

Подсказка

Технически риск здесь — регуляторный и не полностью контролируется командой. Но есть и политический риск: как отреагирует заказчик, если увидит частичный запуск как признание того, что дедлайн уже сорван? Подумайте, какой из вариантов на самом деле лучше защищает отношения с заказчиком, а не только формальные сроки.

Структура ответа: расчёт EMV по вариантам (где применимо) → проверка вторичных рисков → явный выбор с обоснованием → политический/репутационный аргумент, если он есть

HR-платформа: комплаенс против контракта с крупным клиентом

Проект: HR-платформа для подбора персонала

Ситуация

После истории с требованием аудита по 152-ФЗ выяснилось: полное соответствие новым требованиям к защите персональных данных кандидатов потребует ещё 4 недели доработки. У компании подписан контракт с крупным корпоративным клиентом на подключение через 2 недели, со штрафной санкцией за задержку.

Предложенные варианты

- Вариант А — задержать подключение клиента на 4 недели ради полного соответствия требованиям — риск потери клиента и контрактного штрафа.
- Вариант Б — подключить клиента через 2 недели с частичным соответствием и планом «быстрого следования» (fast-follow) для оставшихся мер защиты — риск регуляторных последствий в переходный период.

Подсказка

Прежде чем выбирать между А и Б, проверьте: действительно ли это исчерпывающий список вариантов? Можно ли изменить не срок и не уровень защиты данных, а сам объём того, что подключается клиенту через 2 недели — и как эта третья опция меняет расчёт риска для обеих сторон.

Структура ответа: расчёт EMV по вариантам (где применимо) → проверка вторичных рисков → явный выбор с обоснованием → политический/репутационный аргумент, если он есть

Итоги занятия

Хорошее управление рисками — это не выбор «безопасного» варианта, а выбор варианта, безопасного по расчёту